

Subic Bay Home Services

End-to-End QA Reports — PRD 7

This document consolidates two QA cycles run against the application:

- **Part 1 — First-pass End-to-End QA + Multi-User Simulation** (full lifecycle, security, mobile).
- **Part 2 — Deep Second-Pass QA** (edge cases, permission boundaries, refresh persistence, duplicate actions, notification correctness, deep mobile).
- **Part 3 — Regression Verification** of the original failures.

Field	Value
Project	Subic Bay Home Services (React + Node/Express + MySQL)
Frontend URL	http://localhost:3001 (CRA dev server)
Backend URL	http://localhost:3000 (Node/Express 5, ESM)
Date tested	2026-06-09
Branch	main
Database state	Fresh DROP + 11 migrations + seed (services_web_app)
Email mode	Dev console (EMAIL_DEV_MODE=true) - links logged, no SMTP
Accounts	28 total: 10 client + 8 provider test accounts, 2 admins, seed users
Browser/viewport	Chromium preview @ 375x812 (mobile) + API harness
Overall verdict	PARTIAL PASS - Demo-ready; NOT public-launch-ready

Test technique note. Because the API enforces IP-keyed rate limits (login 5/15min, register 10/hr, booking 20/hr), bulk accounts were created via direct DB insert and authenticated with directly-minted JWTs (the dev JWT_SECRET is known). **All behavioral assertions went through the real HTTP API.** The rate limiters themselves were tested separately and all triggered correctly.

Part 1 — First-Pass End-to-End QA Report

1. Executive Summary

Metric	Result
Overall status	PARTIAL PASS
Launch readiness	Ready for DEMO / Not yet ready for public launch
Critical blockers found	0
High priority bugs	1 (admin message-logs endpoint returns 500)
Medium priority bugs	4 (duplicate-booking 500, inactive-provider booking, no price validation, no email verification)
Low priority bugs	3 (no content-length validation, post-auth approval not re-checked, currency hardcoded)
Automated checks	80 API assertions - 73 passed (1 original failure was a false positive)

The core marketplace lifecycle — signup → admin approval → provider mode → service creation → service approval → browse → booking → accept/decline/complete → messaging → notifications → profile/password — works end-to-end. Access control and data isolation are solid (0 critical failures across all permission-boundary tests). The defects found are an isolated broken admin feature, weak input validation, and a booking-layer availability gap.

2. Test Environment

See cover page for full environment details. 28 accounts exercised; email gated by admin approval only (no email-verification token flow exists).

3. Account Matrix

Account	Role	Email Verified	Admin Approved	Services	Bookings	Notes
client01-09@test.local	client	n/a*	approved	-	15 bookings	Booking/messaging actors
client10@test.local	client	n/a*	rejected	-	-	Login correctly blocked
provider01@test.local	provider	n/a*	approved	House/Deep Cleaning	received	Active
provider02@test.local	provider	n/a*	approved	Plumbing Repair	received	Set INACTIVE (availability test)
provider03-06@test.local	provider	n/a*	approved	Elec/Lawn/Appliance/Moving	received	Active
provider07@test.local	provider	n/a*	approved	Pest Control	-	Service rejected by admin
provider08@test.local	provider	n/a*	rejected	-	-	Login correctly blocked
admin@example.com	admin	n/a	seeded	-	-	admin1234
admin@test.com	admin	n/a	seeded	-	-	Admin123

* No email-verification step exists (see BUG-006); accounts are gated solely by admin approval.

4. Flow Results (condensed)

#	Flow	Status	Notes
2	Signup + validation (empty/invalid/weak/mismatch/duplicate)	PASS	All negatives rejected with 400

#	Flow	Status	Notes
2	Login before/after approval / after rejection	PASS	Pending & rejected blocked; approved gets token
2	Email verification token flow	N/A	Not implemented - BUG-006
3	Admin approve/reject, pending list updates, notifications	PASS	16 approved, 2 rejected; list 23->5
3	Non-admin/unauth blocked from /admin/*	PASS	403 / 401
4	Provider mode: profile/bio update, availability persists	PASS	Bio not hardcoded; toggle persists
5	Service create + missing-title; admin approve/reject	PASS	Pending hidden; approved visible; rejected 404
5	Invalid price / gibberish content	FAIL	Accepted - BUG-004, BUG-005
6	Browse / detail / nonexistent 404 / currency	PASS	Approved-only; rejected & inactive hidden
7	22 booking rows; accept/decline/complete/cancel; filters	PASS	Self-book & cross-user cancel blocked
7	Duplicate booking	WARN	Prevented, but returns 500 - BUG-002
7	Book inactive provider via API	FAIL	Allowed - BUG-003
8	Conversation start/reply/order/list; non-participant 403	PASS	Isolation enforced
8	Admin message logs	FAIL	500 error - BUG-001
9	Notifications: recipient, isolation, mark-read, count	PASS	Cannot read/modify others'
10	Profile update, pw verify/change, weak-pw, old-pw fails	PASS	Old JWT correctly invalidated
11	Auth, invalid token, spoofed header, RBAC, rate limits	PASS	See section 7
12	Mobile 375px (12 pages)	PASS	See section 8

5. Booking Matrix (representative)

Client	Provider	Service	Action	Expected	Actual	Status
client01	provider01	House Cleaning	book	201	201	PASS
client02	provider02	Plumbing Repair	book	201	201	PASS
client03	provider03	Electrical Repair	book	201	201	PASS
client01	provider01	House Cleaning	accept (provider)	200 accepted	200	PASS
client02	provider03	Electrical	decline (provider)	200 declined	200	PASS
client03	provider04	Lawn Care	complete (provider)	200 completed	200	PASS
client05	provider05	Appliance	cancel (client)	200 cancelled	200	PASS
client01	provider01	House Cleaning	DUPLICATE	400 blocked	500	FAIL
provider01	(self)	House Cleaning	self-book	400	400	PASS
client09	(other)	-	cancel others' booking	403	403	PASS
freshClient	provider02 (inactive)	Plumbing	book	block	201	FAIL

Total: 15 successful bookings + 4 seeded + duplicate/self/inactive attempts = 22 booking rows (>20 attempts).

6. Notification Matrix

Trigger	Expected Recipient	Actual	Message correct	Status
Account approved	approved user	user 7	Your account has been approved...	PASS
Account rejected	rejected user	user 16	...was not approved	PASS
Service approved	owning provider	yes	...approved and now visible	PASS
Service rejected	owning provider	yes	...was not approved	PASS

Trigger	Expected Recipient	Actual	Message correct	Status
Booking created	provider (+client confirm)	16 created	New booking request...	PASS
Booking accepted	client	yes	...was accepted	PASS
New message	provider	yes	...new message about	PASS
Cross-user leakage	none	all userId match owner	-	PASS
Mark another's read	blocked	unchanged (is_read=0)	-	PASS

7. Security Regression Results

Test	Expected	Actual	Status	Severity
Provider API without token	401	401	PASS	-
Invalid/garbage token	401	401	PASS	-
Spoofed x-user-id header (no token)	ignored -> 401	401	PASS	-
Non-admin -> /admin/pending-users	403	403	PASS	-
Non-admin -> approve user	403	403	PASS	-
Unauthenticated -> admin API	401	401	PASS	-
Cancel another user's booking	403	403	PASS	-
Read another user's conversation	403	403	PASS	-
Read/modify another user's notification	blocked	blocked	PASS	-
Old JWT after password change	401	401 (verified)	PASS	-
Rejected user login	blocked	blocked	PASS	-
Pre-issued token, user later rejected	ideally blocked	valid until expiry	WARN	Low
Register rate limit (10/hr)	429	429	PASS	-
Login rate limit (5/15min)	429	429	PASS	-

No critical or high security failures. Authentication, RBAC, and cross-user data isolation all hold.

8. Mobile Responsiveness Results (375px)

Page	Full-body overflow	Status	Notes
Landing /	0 px	PASS	-
Login	0 px	PASS	Form usable (2 inputs)
Register	0 px	PASS	6 inputs fit
Forgot password	0 px	PASS	-
Client Dashboard	0 px	PASS	Nav condensed, all links fit (no hamburger)
Browse Services	0 px	PASS	Cards stack
Service Detail	0 px	PASS	Currency shows peso (BUG-008)
My Bookings	0 px	PASS	Status tabs usable
Messages	0 px	PASS	Chat list + thread
Profile	0 px	PASS	-
Admin Dashboard	0 px	PASS	Tables scroll in overflow-x:auto container
Admin Messages	n/a	WARN	Renders but data fails to load (BUG-001)

No full-body horizontal overflow on any page. No console errors.

9. Bug List (Pass 1)

BUG-001 Admin Message Logs endpoint returns 500		HIGH
Area	Backend/src/controllers/adminController.js:150 (getMessageLogs)	
Steps to Reproduce	GET /api/admin/message-logs?page=1&limit=2 as admin -> 500 {"message":"Failed to load message logs"}.	
Expected Result	200 with paginated message list.	
Actual Result	500. Server log: ER_WRONG_ARGUMENTS: Incorrect arguments to mysql_stmt_execute on '... LIMIT ? OFFSET ?'. The admin Message Logs feature is completely non-functional.	
Likely Cause	MySQL prepared statements (db.execute) cannot bind LIMIT/OFFSET as parameters in this mysql2/MySQL version.	
Recommended Fix	Inline the validated integers into the SQL (already sanitized via parseInt/Math.min), or use db.query instead of db.execute for this statement.	
Launch Blocker	No for demo; YES for public launch if message-logs is a shipped admin feature.	

BUG-002 Duplicate booking returns 500 instead of 400		MEDIUM
Area	Backend/src/controllers/bookingController.js:103 (submitBooking catch block)	
Steps to Reproduce	Client books a service they already have a pending/accepted booking for -> 500 'Failed to submit booking'.	
Expected Result	400 with a clear 'You already have an active booking request for this service.' message.	
Actual Result	500 generic error. The model correctly throws and NO duplicate row is created - only the response is wrong.	
Likely Cause	The controller only maps 'You cannot book your own service' and 'Service not found or unavailable'; the duplicate message falls through to a generic 500.	
Recommended Fix	Add a branch mapping the duplicate message to 400 with the real message.	
Launch Blocker	No (functionally safe) but misleading UX.	

BUG-003 Booking endpoint ignores provider availability		MEDIUM
Area	Backend/src/models/bookingModel.js:84 (createBooking)	
Steps to Reproduce	Provider02 set is_provider_active=false; service stays approved+visible. Client POST /api/bookings directly -> 201 created.	
Expected Result	Blocked - an unavailable provider should not be bookable.	
Actual Result	201 created. Browse/detail correctly hide inactive providers, but the booking API allows it (defense-in-depth gap).	
Likely Cause	createBooking validates service approval_status/is_visible/is_deleted but NOT provider_profile.is_provider_active.	
Recommended Fix	Add JOIN provider_profile pp ... AND pp.is_provider_active = TRUE to the service-eligibility check.	
Launch Blocker	No.	

BUG-004 No server-side price validation (negative prices accepted)		MEDIUM
Area	Backend/src/controllers/providerController.js:60 / providerModel.js:97	
Steps to Reproduce	POST /api/provider/services with pricingType:'fixed', priceAmount:-50 -> 201, stored as -50.	
Expected Result	400 - reject non-positive prices for fixed/hourly pricing.	
Actual Result	201 created; -50 persisted.	
Likely Cause	Only title + pricingType are required; priceAmount is not validated.	
Recommended Fix	Validate priceAmount is a positive number when pricingType != 'quote'.	
Launch Blocker	No.	

BUG-005 No content-length/quality validation on services		LOW
Area	Backend service creation	
Steps to Reproduce	Create service with title:'x', description:'asdf' -> 201.	
Expected Result	400 - enforce minimum title/description lengths.	
Actual Result	201 created.	
Likely Cause	Only title + pricingType are required; no min-length checks.	
Recommended Fix	Enforce minimum title/description lengths.	
Launch Blocker	No.	

BUG-006 No email-verification flow		MEDIUM
Area	Backend authController.registerUser	
Steps to Reproduce	Register a new account; observe only a confirmation email is sent (no verification token/link/endpoint).	
Expected Result	Verification link + invalid/expired-token handling (per PRD section 2).	
Actual Result	No verification token, endpoint, or users column exists. Access is gated solely by admin approval.	
Likely Cause	Email verification was never implemented; admin approval is the only gate.	
Recommended Fix	Either implement email verification or formally mark it out-of-scope (admin approval is the gate).	
Launch Blocker	Decision needed before public launch.	

BUG-007 requireAuth does not re-check approval status		LOW
Area	Backend/src/middleware/auth.js (requireAuth)	
Steps to Reproduce	Mint/issue a token, then reject/deactivate that user; the token still authorizes protected routes until expiry (24h).	
Expected Result	401/403 for rejected or deactivated users.	
Actual Result	200 - protected route still reachable. Low risk: rejected users cannot obtain a token via login.	
Likely Cause	requireAuth verifies JWT + password_changed_at but not approval_status/is_active.	
Recommended Fix	Re-check approval_status/is_active in requireAuth (optional hardening).	
Launch Blocker	No.	

BUG-008 Currency symbol hardcoded to peso while DB stores other codes		LOW
Area	Frontend service detail rendering	
Steps to Reproduce	Open a service whose DB currency is 'CAD'; UI renders the peso symbol regardless.	
Expected Result	Symbol derived from stored currency code, or stored code standardized to PHP.	
Actual Result	UI always renders peso; DB stores mixed CAD/PHP. Correct for the Subic Bay (PH) context but a data/display mismatch.	
Likely Cause	Currency symbol is hardcoded in the UI.	
Recommended Fix	Standardize stored currency to PHP, or render the symbol from the stored code.	
Launch Blocker	No.	

False positive (not a bug)

The harness initially flagged 'old JWT still valid after password change.' Direct verification with a clearly past-dated token returned 401 Session expired — the invalidation logic works correctly. The harness artifact was a sub-second timing collision (token minted in the same wall-clock second as the password change). **Reclassified to PASS.**

10. Final Recommendation

Ready for demo: YES Ready for public launch: NO (address High + Medium items first).

Must fix before public launch: BUG-001 (admin message-logs 500), BUG-002 (duplicate-booking 500), BUG-003 (enforce provider availability), BUG-004 (validate service price), BUG-006 (decide email verification).

Nice to fix later: BUG-005 (content validation), BUG-007 (re-check approval), BUG-008 (currency), replace window.confirm() delete dialog with an in-app modal.

Bottom line: every core user journey completes correctly and the security/permission model is sound. Before public launch, fix the one broken admin feature and the medium-severity validation/booking gaps.

Part 2 — Deep Second-Pass QA Report

Scope: edge cases, permission boundaries, refresh persistence, duplicate actions, mobile responsiveness, notification correctness. Same test accounts, fresh JWTs. No happy-path repeats.

Result: 50 API assertions + 6 deep mobile checks. 48/50 effectively passed. One genuinely new bug surfaced (booking state machine), plus two harness artifacts that verified clean.

Coverage Summary

Category	Checks	Pass	Notes
Edge cases	17	16	Missing fields, nonexistent/rejected/deleted targets, invalid status, duplicate category, delete-category-with-services, nonexistent updates - all handled
Permission boundaries	11	11	ALL clean - cross-provider mutation, cross-user booking/conversation, admin sub-routes, notification ownership, provider booking isolation
Refresh persistence	6	6	Visibility toggle, availability, profile, booking status persist; hidden service drops from browse
Duplicate actions	5	4	Idempotent conversation reuse & mark-all-read OK; state-machine flip fails
Notification correctness	11	11	Correct recipient/type for created/accepted/declined/cancelled/completed/reply; ordering, soft-delete, unread count all correct

New Bug Found in Deep Pass

BUG-D01	Provider booking status has no state-machine guard	MEDIUM
Area	Backend/src/models/bookingModel.js:130 (updateBookingStatus, provider branch)	
Steps to Reproduce	1) Client books service (pending), then PATCH /api/bookings/:id/cancel -> cancelled. 2) Provider PATCH /api/bookings/:id/respond {status:'accepted'} -> 200, DB status becomes 'accepted'. Also: accepted -> declined returns 200 (flips); completed -> declined returns 200 (flips).	
Expected Result	A booking in a terminal state (cancelled, declined, completed) cannot be transitioned again; a provider cannot revive a cancelled booking.	
Actual Result	200 in every case (verified twice). A cancelled booking was resurrected to 'accepted'; an accepted booking was flipped to 'declined'.	
Likely Cause	The provider branch of updateBookingStatus checks only role + ownership, not currentStatus. The client (cancel) branch DOES guard; the provider branch does not.	
Recommended Fix	Add a guard in the provider branch - only allow pending->accepted declined and accepted->completed; reject transitions out of terminal states with 400.	
Launch Blocker	No, but causes confusing state and potential double-booking of a provider's time.	

Observations (confirmed, not new bugs)

- **Currency:** stored values are mixed (CAD, PHP) while the UI always renders the peso symbol (re-confirms BUG-008).
- **Dark mode:** the app does not implement a dark theme — prefers-color-scheme: dark renders the normal light theme (no breakage, just unimplemented).

Harness Artifacts Corrected (NOT bugs)

Initially flagged	Verdict after clean re-test
'Cancel already-cancelled booking -> 404'	PASS - returns 400 'Cannot cancel...'; the 404 came from a contaminated (undefined) booking id caused by a pre-existing duplicate from Pass 1

Initially flagged	Verdict after clean re-test
'Mark-all-read does not zero unread count'	PASS - endpoint returns {unreadCount} (not {count}); verified 3 -> 0

Permission-Boundary Detail (all passed)

Test	Expected	Actual	Status
Provider updates another provider's service (PUT)	404 not found	404	PASS
Provider toggles another provider's service visibility	404	404	PASS
Provider deletes another provider's service	404	404	PASS
Victim service intact after cross-provider attempts	not modified	intact	PASS
Client uses provider respond endpoint on own booking	403	403	PASS
Unrelated user responds to a booking	403	403 (Critical area)	PASS
Non-participant replies to a conversation	403	403 (Critical area)	PASS
Non-admin GET admin categories	403	403	PASS
Non-admin GET contact submissions	403	403	PASS
Cannot soft-delete another user's notification	unchanged	deleted_at=null	PASS
Provider bookings list isolated to self	no other rows	ok (Critical area)	PASS

Edge Cases & Duplicate Actions Detail

Test	Expected	Actual	Status
Booking missing providerId	400	400	PASS
Booking nonexistent service	404	404	PASS
Booking rejected service	404 unavailable	404	PASS
Booking soft-deleted service	404 unavailable	404	PASS
Respond with invalid status	400	400	PASS
Cancel already-cancelled booking (clean re-test)	400 Cannot cancel	400	PASS
Provider accepts a CANCELLED booking	block (400)	200 resurrected	FAIL
Start conversation empty message	400	400	PASS
Start conversation about rejected service	400 not approved	400	PASS
Reply to nonexistent conversation	404	404	PASS
Profile update missing fields	400	400	PASS
Password change mismatched confirm	400	400	PASS
Create duplicate category	409	409	PASS
Delete category with services	409	409	PASS
Update nonexistent category	404	404	PASS
Approve already-approved service / user	400	400	PASS
Reject already-approved service / user	400 only pending	400	PASS
Approve nonexistent service	404	404	PASS
Re-start conversation reuses same thread	same id	same id	PASS
Mark-all-read twice (idempotent)	200	200	PASS
Provider flips accepted -> declined	block (400)	200 flipped	FAIL

Notification Correctness Detail (all passed)

Test	Expected	Actual	Status
Booking created -> provider notified	>=1	1	PASS
Booking declined -> client notified	>=1	1	PASS
Booking cancelled -> provider notified	>=1	1	PASS
Booking completed -> BOTH parties notified	client>=1 & provider>=1	c:1 p:1	PASS
Provider reply -> client gets reply_received	reply_received	reply_received	PASS
Client message -> provider gets message_received	message_received	message_received	PASS
Mark-all-read zeroes unread count	0	3 -> 0	PASS
Soft-deleted notification leaves main list	absent	absent	PASS
Soft-deleted notification appears in /deleted	present	present	PASS
Notifications ordered unread-first	unread before read	ok	PASS

Refresh Persistence Detail (all passed)

Test	Expected	Actual	Status
Service visibility toggle persists	isVisible=false	false	PASS
Hidden service removed from Browse	absent	absent	PASS
Service visibility restore persists	isVisible=true	true	PASS
Profile update persists across re-fetch	firstName=Persisted	Persisted	PASS
Booking status persists across re-fetch	accepted	accepted	PASS
Session persists across browser reload	stay logged in	stayed on dashboard, token intact	PASS

Deep Mobile Results (375px)

Page / surface	Full-body overflow	Status	Notes
Provider Dashboard /provider-mode	0 px	PASS	Bio persisted, availability toggle usable
Reset Password	0 px	PASS	2 inputs, expiry notice
Admin -> Users / Services / Categories / Inquiries / Messages	0 px each	PASS	Wide tables (520-1021px) scroll within overflow-x:auto containers
Dark mode (emulated)	0 px	WARN	No dark theme; renders light, no breakage
Session reload persistence	-	PASS	Reload stays on /client-dashboard, token intact, no bounce to login

Permission boundaries are the strongest area — every cross-user / cross-role / ownership probe was correctly rejected (0 failures, including the Critical-severity ones).

Part 3 — Regression Verification

Re-ran ONLY the failed cases from the first-pass QA report. No code fixes were applied between passes (the first report only documented the bugs — remediation was not requested), so this run confirms each defect is still live and reproducible.

Bug ID	Title	Severity	Expected (if fixed)	Actual now	Verdict
BUG-001	Admin message-logs endpoint	High	200 with messages	500 (LIMIT/OFFSET bind)	STILL FAILING
BUG-002	Duplicate-booking status code	Medium	400 + clear message	500 'Failed to submit booking'	STILL FAILING
BUG-003	Booking inactive provider	Medium	blocked 400/404	provider_active=0, POST -> 201	STILL FAILING
BUG-004	Negative price validation	Medium	400 rejected	priceAmount:-99 -> 201	STILL FAILING
BUG-005	Service content validation	Low	400 rejected	title:'x', desc:'asdf' -> 201	STILL FAILING
BUG-006	Email verification flow	Medium	endpoint/column exists	no endpoint, no verif column	STILL FAILING
BUG-007	Re-check approval in requireAuth	Low	401/403 for rejected user	approval=rejected, /profile -> 200	STILL FAILING
BUG-008	Currency code consistency	Low	all PHP	stored CAD,PHP; UI hardcodes peso	STILL FAILING

Regression summary: 0 fixed · 0 partial · 8 still failing. (The original false-positive — 'old JWT not invalidated after password change' — remains correctly PASS and is not re-listed since it was never a defect.)

Consolidated Open-Bug List (both passes)

ID	Severity	Area	Status
BUG-001	High	Admin message logs (500)	Open
BUG-D01	Medium	Booking provider-side state machine	Open (new)
BUG-002	Medium	Duplicate-booking 500	Open
BUG-003	Medium	Inactive-provider booking allowed	Open
BUG-004	Medium	No price validation	Open
BUG-006	Medium	No email verification	Open (decision)
BUG-005	Low	No content-length validation	Open
BUG-007	Low	Approval not re-checked post-auth	Open
BUG-008	Low	Currency code/symbol mismatch	Open

Net Assessment

Still demo-ready, NOT public-launch-ready. Notably, BUG-001, BUG-002, and BUG-D01 share a common shape (error-handling / state-machine in the booking + admin controllers) and could be fixed together quickly. Every core user journey completes correctly and the security/permission model is sound (0 critical failures across two full passes and dozens of permission-boundary probes).